

SAE CYBER 401

Sécuriser un système d'information

Martin Frain, Raphael Parre

IUT de Blois

Table des matières

Table des matières	1
1 Objectif	2
2 Réseau de l'entreprise.....	3
2.1 Site Principal	3
2.2 DMZ.....	4
2.3 LAN	5
2.4 Internet.....	6
2.5 Site Secondaire	7
3 Configuration des appareils.....	8
4 Attaques	15
4.1 Liste des outils de pentesting.....	15
4.2 Phase attaquant externe.....	15
4.3 Phase attaquant interne	20
5 Rôle dans l'équipe	23
6 Conclusion	24

1 Objectif

Ce projet s'inscrit dans le cadre de la SAÉ 401, dont l'enjeu majeur est la conception, le déploiement et la sécurisation complète d'une infrastructure réseau multi-sites. Cette mise en situation nous place au cœur des responsabilités d'une équipe d'administration et de cybersécurité. Notre mission principale consiste à garantir la disponibilité des services critiques (Web, Mail, DNS) tout en assurant l'intégrité et la confidentialité des échanges entre le site principal et sa succursale.

L'architecture repose sur une segmentation fine du réseau via des VLANs (VLAN 10 pour les utilisateurs, VLAN 30 pour la DMZ et VLAN 99 pour l'administration) afin de cloisonner les flux et de limiter la surface d'attaque.

Un tunnel VPN IPsec, configuré entre le routeur principal et le routeur secondaire, assure la sécurité des communications inter-sites sur un réseau public non fiable. Au-delà de la connectivité, l'accent est mis sur le durcissement des équipements Cisco, en appliquant des protocoles de gestion sécurisés (SSH), des listes de contrôle d'accès (ACL) rigoureuses et des mécanismes de protection de couche 2 (Port-Security, BPDU Guard).

Ce rapport détaille ainsi les phases de configuration, les tests d'intrusion réalisés pour valider la robustesse de l'édifice, et les mesures correctives apportées suite à l'analyse des vulnérabilités.

2 Réseau de l'entreprise

2.1 Site Principal

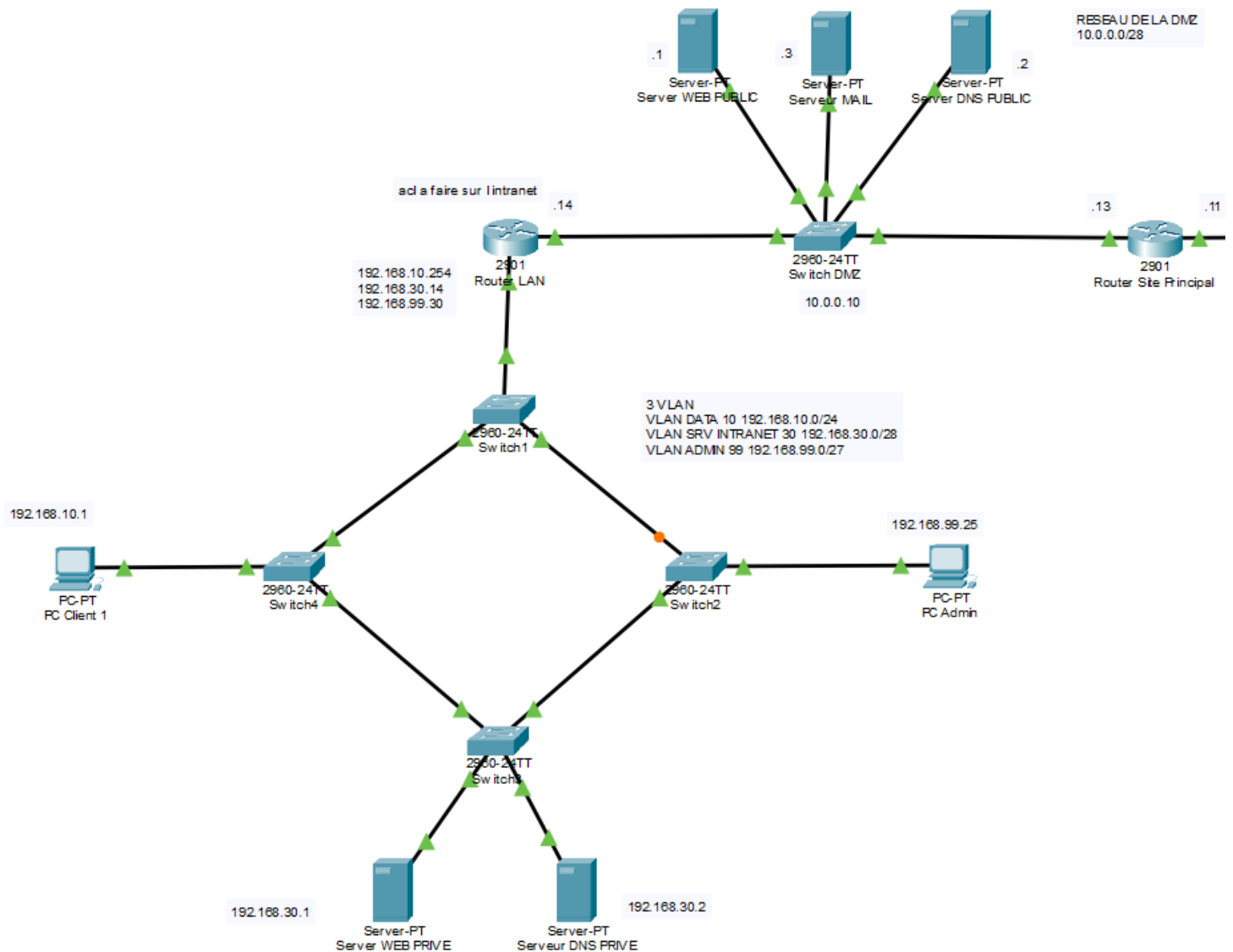


Figure 1 Réseau de l'entreprise (DMZ et LAN)

Le site principal est séparé en 2 réseaux (DMZ et LAN). La DMZ accueille 3 serveurs, serveur WEB de l'entreprise, serveur MAIL et serveur DNS public. Nous utiliserons des machines virtuelles afin de simuler les serveurs. Le LAN accueillera lui 3 VLAN, le VLAN DATA, le VLAN INTRANET et le VLAN ADMIN.

2.2 DMZ

Serveur WEB public www.bordeaux.rt :

IP : 10.0.0.1

Masque : 255.255.255.240

Passerelle : 10.0.0.13

DNS : 192.168.30.2

Serveur DNS public :

IP : 10.0.0.2

Masque : 255.255.255.240

Passerelle : 10.0.0.13

DNS : 203.0.113.253

Serveur Mail :

IP : 10.0.0.3

Masque : 255.255.255.240

Passerelle : 10.0.0.13

DNS : 192.168.30.2

2.3 LAN

Serveur WEB intranet.bordeaux.rt

IP : 192.168.30.1 (VLAN 30 INTRANET)

Masque : 255.255.255.240

Passerelle : 192.168.30.14

DNS : 192.168.30.2

Serveur DNS privé :

IP : 192.168.30.2 (VLAN 30 INTRANET)

Masque : 255.255.255.240

Passerelle : 192.168.30.14

DNS : 192.168.30.2

PC Admin :

IP : 192.168.99.25 (VLAN 99 ADMIN)

Masque : 255.255.255.224

Passerelle : 192.168.99.30

DNS : 192.168.30.2

PC Client :

IP : 192.168.10.1 (VLAN 10 DATA)

Masque : 255.255.255.0

Passerelle : 192.168.10.254

DNS : 192.168.30.2

2.4 Internet

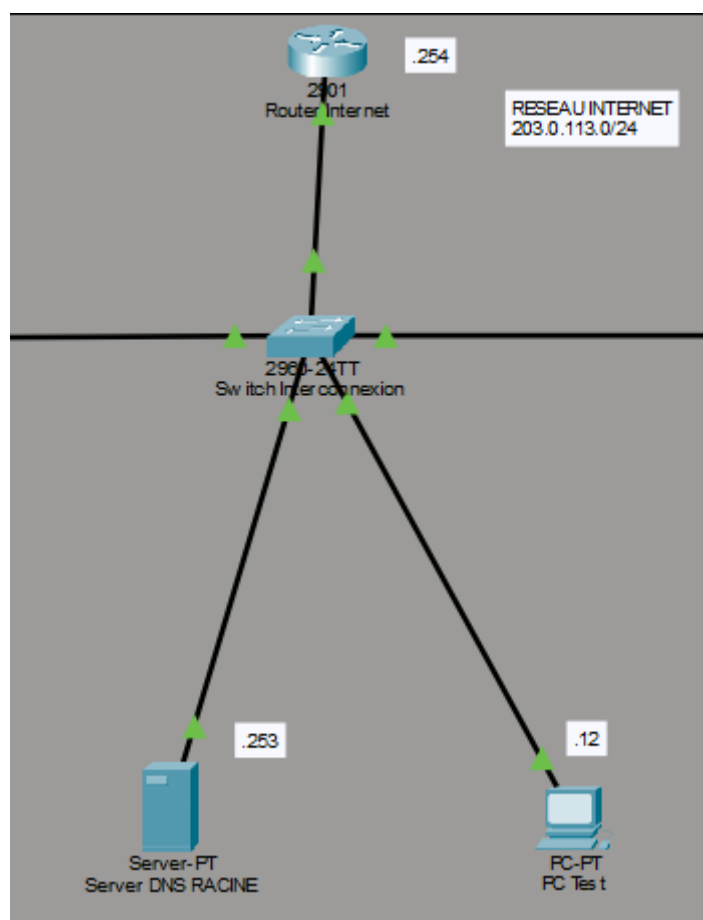


Figure 2 Internet

Serveur DNS .rt

IP : 203.0.113.253

Masque : 255.255.255.0

Passerelle : 203.0.113.254

DNS : 203.0.113.253

PC test

IP : 203.0.113.12

Masque : 255.255.255.0

Passerelle : 203.0.113.254

DNS : 203.0.113.253

2.5 Site Secondaire

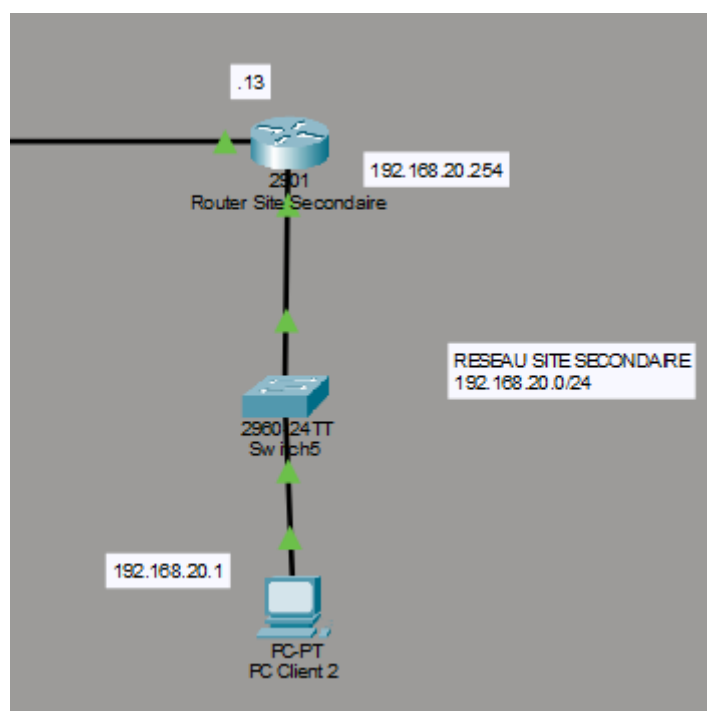


Figure 3 Site secondaire

PC Client 2 :

IP : 192.168.20.1

Masque : 255.255.255.0

Passerelle : 192.168.20.254

DNS : 192.168.30.2

Les switchs 1 2 3 et 4 : 192.168.99. « 1-2-3-4 »

Le switch DMZ 10.0.0.10

Le switch 5 : 192.168.20.10

3 Configuration des appareils

L'entièreté des Switchs est protégée contre les attaques internes visant la couche de liaison de données. Voici un exemple d'interface sécurisée :

interface GigabitEthernet0/4

```
switchport mode access
switchport nonegotiate
switchport port-security maximum 2
switchport port-security
switchport port-security violation restrict
switchport port-security mac-address sticky
shutdown
spanning-tree portfast
spanning-tree bpduguard enable
```

Nous avons désactivé toutes les interfaces GigabitEthernet non utilisés ce qui permet d'éviter des intrusions physiques (dans le cas d'une véritable entreprise). Ensuite nous avons protégés nos switchs des sauts de VLAN, avec les commandes : `switchport mode access` et `switchport nonegotiate`. Ces commandes permettent de forcer l'interface à agir comme un port terminal et de désactiver le protocole DTP. Cela rend impossible l'attaque par switch spoofing, où un attaquant simule être un switch en forçant un lien trunk et accéder à tous les VLANs de l'entreprise.

Pour protéger des attaques utilisant des adresses MAC nous avons utilisé :

```
switchport port-security maximum 2
switchport port-security
switchport port-security violation restrict
switchport port-security mac-address sticky
```

Ces commandes permettent de limiter le port à deux adresses MAC mémorisées dynamiquement. Si un appareil inconnu se branche, le trafic

sera bloqué. Cette limitation d'adresse MAC permet de se protéger des saturation d'adresses MAC ainsi que l'usurpation d'adresses physique.

Pour finir la protection des switchs, nous avons intégré une protection de l'arbre spanning-tree :

```
spanning-tree portfast
spanning-tree bpduguard enable
```

Ces commandes désactivent un port utilisateur s'il reçoit un paquet BPDU qui est censé venir d'un vrai switch. Cette protection contre directement le root spoofing où un attaquant branche un switch pour forcer le détournement du trafic réseau vers sa machine.

De plus ces switchs bénéficie de la protection de l'accès privilégié (mode enable). Un mot de passe, qui est chiffrer, est nécessaire pour passer cette étape. Ils sont aussi équipés d'un timeout qui déconnecte l'utilisateur après 1 minute d'inactivité. Et pour finir ces switchs sont accessible en ssh uniquement par le PC administrateur (IP en 192.168.99.1 pour le switch1, etc). Cette configuration est la même pour tout les switch de notre réseau.

```
enable secret 5 $1$qW/L$8B1aNcypo/mc5i6T2ASp..
```

```
ip access-list standard ACL-ADMIN-ONLY
```

```
    permit 192.168.99.25
```

```
    deny    any
```

```
line vty 0 4
```

```
    access-class ACL-ADMIN-ONLY in
```

```
    exec-timeout 1 0
```

```
    login local
```

```
    transport input ssh
```

```
line vty 5 15
```

```
    access-class ACL-ADMIN-ONLY in
```

```
    exec-timeout 1 0
```

```
    login local
```

```
    transport input ssh
```

Pour ce qui est des routeurs, les mesures de sécurité sont les mêmes (Chiffrement, protection enable, admin ssh, timeout)

```
ip access-list standard ACL-ADMIN-ONLY
    permit 192.168.99.25
    deny    any

line con 0
    exec-timeout 1 0
line aux 0
line vty 0 4
    access-class ACL-ADMIN-ONLY in
    exec-timeout 1 0
    login local
    transport input ssh

service password-encryption
username admin
privilege 15 secret 5 $1$/y3s$BsFJy1x/jx9eEX5E5Rqd01
```

Mais en fonction du routeur la configuration est différente :

Routeur LAN

Le routeur LAN possède plusieurs acls permettant de bloquer l'accès au serveur web intranet depuis la DMZ :

```
ip access-list standard INTRANET
    deny tcp host 10.0.0.1 host 192.168.30.2 eq 80
    deny tcp host 10.0.0.2 host 192.168.30.2 eq 80
    deny tcp host 10.0.0.3 host 192.168.30.2 eq 80
    permit ip any any
```

Pour le routeur du site principal le rôle est différent, c'est le routeur qui fait le lien entre notre réseau et Internet. On y retrouve du PAT (Port Address Translation) afin que le client extérieur au réseau puisse avoir accès au serveur web de l'entreprise. Ce routeur est aussi utile pour le lien VPN.

```
access-list 101 deny ip 192.168.0.0 0.0.255.255 192.168.20.0
0.0.0.255 (ici on empeche le NAT pour le trafic allant vers le
site distant)
```

```
access-list 101 permit ip 10.0.0.0 0.0.0.15 any (autorise la DMZ
à aller sur Internet)
```

```
access-list 101 permit ip 192.168.0.0 0.0.255.255 any (autorise
le LAN à aller sur Internet)
```

```
ip nat inside source static tcp 10.0.0.3 25 203.0.113.11 25
extendable
```

```
ip nat inside source static tcp 10.0.0.2 53 203.0.113.11 53
extendable
```

```
ip nat inside source static tcp 10.0.0.1 80 203.0.113.11 80
extendable
```

```
ip nat inside source static tcp 10.0.0.3 143 203.0.113.11 143
extendable
```

```
ip nat inside source static tcp 10.0.0.1 443 203.0.113.11 443
extendable
```

```
ip nat inside source static tcp 10.0.0.3 465 203.0.113.11 465
extendable
```

```
ip nat inside source static tcp 10.0.0.3 993 203.0.113.11 993
extendable
```

Ici on autorise l'accès au port 80/443 pour le serveur web, le port 53 pour le DNS et les ports 25/465 et 143/993 pour le mail.

Et enfin le routeur du site secondaire, il est très semblable au routeur du site principal sauf qu'il n'a pas de PAT. Il effectue du NAT pour son réseau 192.168.20.0/24 . Il est le routeur relié au routeur site principal par le VPN.

```
access-list 101 deny ip 192.168.20.0 0.0.0.255 192.168.0.0 0.0.255.255 (ici on empêche le NAT pour le trafic allant vers le site distant)
```

```
access-list 101 permit ip 192.168.20.0 0.0.0.255 any (autorise l'accès sur Internet)
```

Maintenant nous allons voir la configuration du VPN entre 2 sites distants

Nous allons ici simuler un réseau privé entre les 2 routeurs en 172.16.0.0/16

On utilise l'interface Tunnel10 et on indique la source et la destination.

```
interface Tunnel10  
  
ip address 172.16.0.2 255.255.0.0  
  
tunnel source 203.0.113.13 (ici nous sommes sur le routeur site secondaire)  
  
tunnel mode ipsec ipv4  
  
tunnel destination 203.0.113.11 (IP du routeur site principal)  
  
tunnel protection ipsec profile IPSECPROFILE
```

Il y a un changement dans la table de routage de ces routeurs, une route vers le réseau distant apparaît :

```
ip route 0.0.0.0 0.0.0.0 203.0.113.254  
ip route 10.0.0.0 255.255.255.240 172.16.0.1  
ip route 192.168.0.0 255.255.0.0 172.16.0.1
```

Pour finir nous allons commenter la configuration des 3 DNS

DNS Racine .rt :

dns.bordeaux.rt	A	203.0.113.11
bordeaux.rt	NS	dns.bordeaux.rt
dns.nantes.rt	A	203.0.113.1
nantes.rt	NS	dns.nantes.rt
rt	NS	dns.rt

Il y a bien 2 délégation vers Bordeaux.rt (notre entreprise) et Nantes.rt (l'entreprise adverse)

DNS Public

dns.bordeaux.rt	A	203.0.113.11
dns.rt	A	203.0.113.253
bordeaux.rt	NS	dns.bordeaux.rt
mail.bordeaux.rt	A	203.0.113.11
imap.bordeaux.rt	A	203.0.113.11
smtp.bordeaux.rt	A	203.0.113.11
www.bordeaux.rt	A	203.0.113.11
rt	NS	dns.rt

Ce DNS sert au réseau extérieur à l'entreprise, on y remarque le serveur web www.bordeaux.rt et les différents services de mail (IMAP et SMTP)

DNS Privé

dns.bordeaux.rt	A	10.0.0.2
dns.rt	A	203.0.113.253
bordeaux.rt	NS	dns.bordeaux.rt
intranet.bordeaux.rt	A	192.168.30.1
www.bordeaux.rt	A	10.0.0.1
mail.bordeaux.rt	A	10.0.0.3
imap.bordeaux.rt	CNAME	mail.bordeaux.rt
smtp.bordeaux.rt	CNAME	mail.bordeaux.rt
rt	NS	dns.rt

Ici on retrouve les services mail en 10.0.0.3, qui est le serveur mail de l'entreprise, le serveur web public `www.bordeaux.rt` et le serveur web `intranet.bordeaux.rt`.

4 Attaques

Afin de tester la sécurité de l'entreprise adverse et la nôtre nous avons effectué des attaques sous forme de pentest afin d'énumérer l'ensemble des failles que nous avons pu exploiter. Ensuite l'objectif sera d'apporter les correctifs nécessaires au réseau informatique de l'autre entreprise pour qu'elle soit sécurisée. De l'autre côté l'entreprise adverse a également pu tester nos défenses en effectuant un pentest.

Malheureusement, l'entreprise adverse n'a pas eu le temps de faire de VLAN Admin donc nous n'avons pas pu faire la partie root malveillant soit la 3ème attaque qui devait être faite. De plus, il n'y avait que très peu d'attaques possibles étant donné que leur réseau n'était pas terminé.

4.1 Liste des outils de pentesting

Netdiscover

Nmap

Dirb & nikto

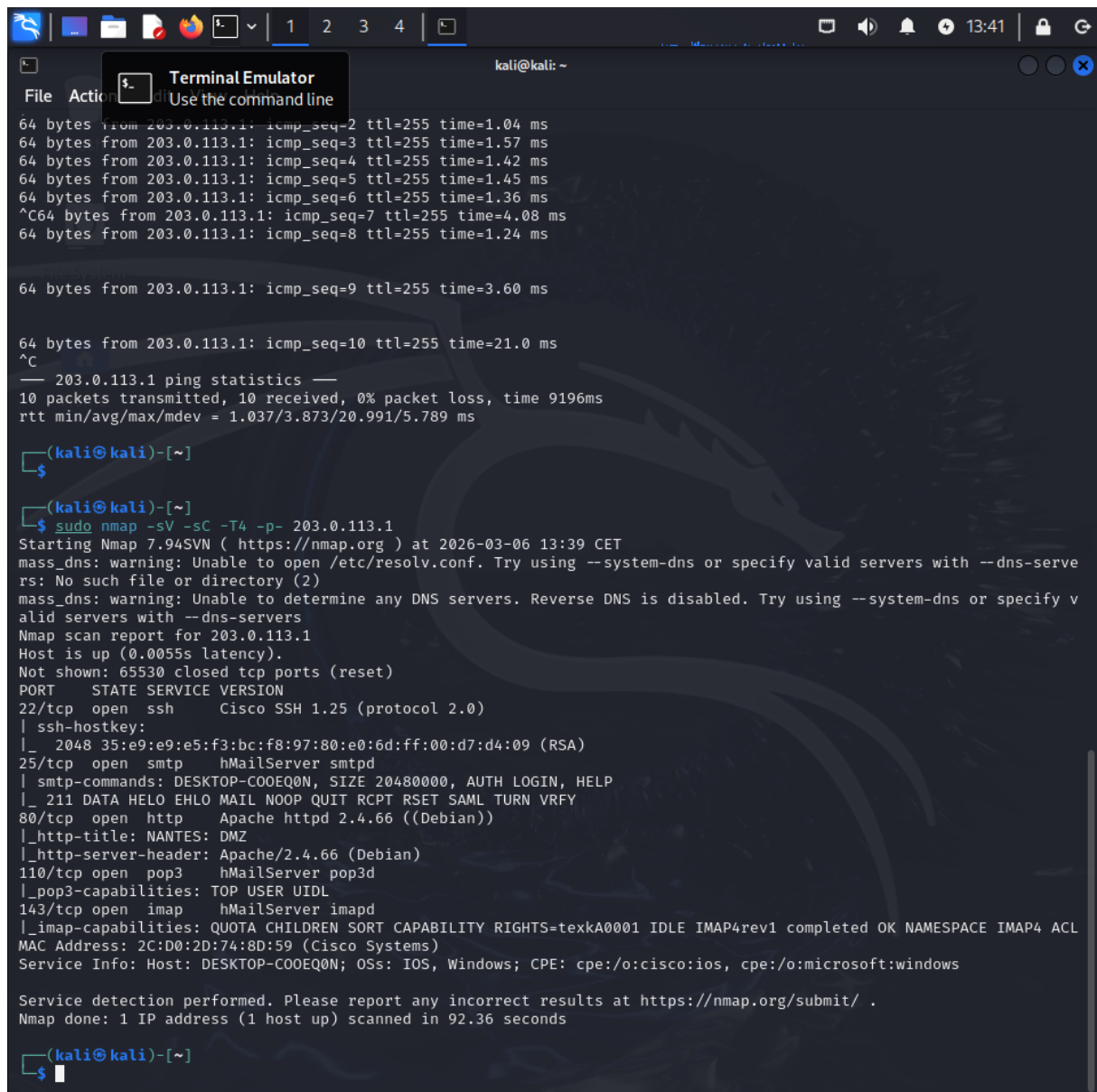
Smtip-enum-users

hydra

4.2 Phase attaquant externe

Dans un premier cas, nous étions un attaquant externe n'ayant qu'accès à l'adresse IP du site principal et secondaire : respectivement 203.0.113.1 (routeur externe / DMZ) et 203.0.113.2 (LAN / Intranet).

Nous avons débuté par une phase de reconnaissance en utilisant nmap sur l'IP 203.0.113.1, qui correspond au routeur principal de l'autre entreprise. L'objectif étant de vérifier si des services sont observables et ouverts.



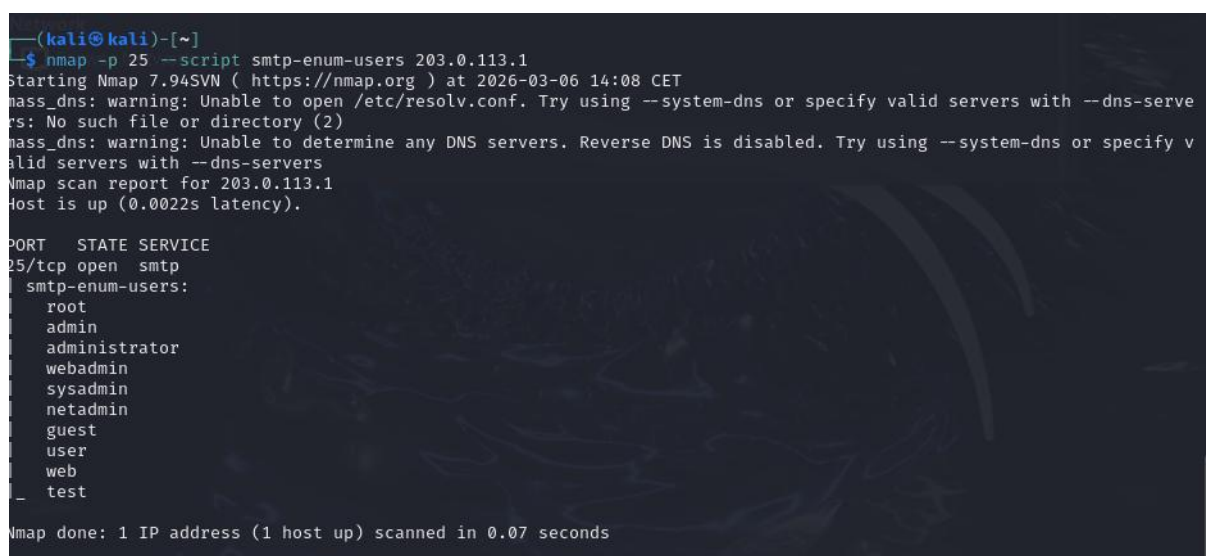
```
kali@kali: ~  
File Action [?] Terminal Emulator  
Use the command line  
64 bytes from 203.0.113.1: icmp_seq=2 ttl=255 time=1.04 ms  
64 bytes from 203.0.113.1: icmp_seq=3 ttl=255 time=1.57 ms  
64 bytes from 203.0.113.1: icmp_seq=4 ttl=255 time=1.42 ms  
64 bytes from 203.0.113.1: icmp_seq=5 ttl=255 time=1.45 ms  
64 bytes from 203.0.113.1: icmp_seq=6 ttl=255 time=1.36 ms  
^C64 bytes from 203.0.113.1: icmp_seq=7 ttl=255 time=4.08 ms  
64 bytes from 203.0.113.1: icmp_seq=8 ttl=255 time=1.24 ms  
  
64 bytes from 203.0.113.1: icmp_seq=9 ttl=255 time=3.60 ms  
  
64 bytes from 203.0.113.1: icmp_seq=10 ttl=255 time=21.0 ms  
^C  
— 203.0.113.1 ping statistics —  
10 packets transmitted, 10 received, 0% packet loss, time 9196ms  
rtt min/avg/max/mdev = 1.037/3.873/20.991/5.789 ms  
  
(kali@kali)-[~]  
$  
  
(kali@kali)-[~]  
$ sudo nmap -sV -sC -T4 -p- 203.0.113.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-06 13:39 CET  
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers: No such file or directory (2)  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 203.0.113.1  
Host is up (0.0055s latency).  
Not shown: 65530 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      Cisco SSH 1.25 (protocol 2.0)  
|_ ssh-hostkey:  
|_  2048 35:e9:e9:e5:f3:bc:f8:97:80:e0:6d:ff:00:d7:d4:09 (RSA)  
25/tcp    open  smtp      hMailServer smtpd  
|_ smtp-commands: DESKTOP-COOEQ0N, SIZE 20480000, AUTH LOGIN, HELP  
|_ 211 DATA HELO EHLO MAIL NOOP QUIT RCPT RSET SAML TURN VRFY  
80/tcp    open  http      Apache httpd 2.4.66 ((Debian))  
|_ http-title: NANTES: DMZ  
|_ http-server-header: Apache/2.4.66 (Debian)  
110/tcp   open  pop3      hMailServer pop3d  
|_ pop3-capabilities: TOP USER UIDL  
143/tcp   open  imap      hMailServer imapd  
|_ imap-capabilities: QUOTA CHILDREN SORT CAPABILITY RIGHTS=texkA0001 IDLE IMAP4rev1 completed OK NAMESPACE IMAP4 ACL  
MAC Address: 2C:D0:2D:74:8D:59 (Cisco Systems)  
Service Info: Host: DESKTOP-COOEQ0N; OSs: IOS, Windows; CPE: cpe:/o:cisco:ios, cpe:/o:microsoft:windows  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 92.36 seconds  
  
(kali@kali)-[~]  
$
```

Figure 4 nmap sur le réseau 203.0.113.1

Nmap a scanné l'ensemble des (65 535) ports sur l'adresse IP 203.0.113.1 et nous renvoie des services ouverts tels que SSH (port 22), smtp (port 25), http (port 80), pop3 (port 110) et imap (port 143). Chaque port est accompagné de sa version en clair dévoilant les versions exactes des logiciels utilisés (Cisco SSH 1.25, Apache httpd 2.4.66 (Debian)). Cela permet de facilement rechercher des failles spécifiques pour chaque protocoles. Le port 22 (SSH) est d'autant plus critique car il est exposé publiquement sur les routeurs ce qui ne devrait pas être le cas. Ainsi n'importe qui peut lancer une connexion SSH et brute force le mot de passe donnant accès à la configuration du routeur.

Pour la partie correctif le principal enjeux est de restreindre l'accès au port 22 depuis l'extérieur via une ACL. L'ACL n'autorisant que l'IP publique spécifique de l'administrateur, ou obliger l'utilisation du VPN IPsec pour l'administration. Sinon pour les ports 80, 25, 110, 143 le plus simple est de les fermer via les fichiers de configurations directement (par exemple port le port 80 il suffit de commenter la ligne LISTEN 80 ce qui fermera le port).

Ensuite nous avons utilisé nmap encore une fois mais cette fois ci en ciblant directement le serveur de messagerie avec le script smtp-enum-users. L'objectif est d'obtenir des adresses mails pour plus tard pouvoir faire du phishing ciblé sur les employés de l'entreprise.



```
—(kali@kali)-[~]
$ nmap -p 25 --script smtp-enum-users 203.0.113.1
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-06 14:08 CET
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers: No such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 203.0.113.1
Host is up (0.0022s latency).

PORT      STATE SERVICE
25/tcp    open  smtp
smtp-enum-users:
  root
  admin
  administrator
  webadmin
  sysadmin
  netadmin
  guest
  user
  web
  test
_
Nmap done: 1 IP address (1 host up) scanned in 0.07 seconds
```

Figure 5 nmap et smtp-enum-users sur 203.0.113.1

Le script permet d'exploiter les commandes SMTP VRFY, EXPN et RCPT TO pour tester l'existence de comptes.

Le serveur hMailServer nous renvoie des réponses aux requêtes et nous permet de lister de nombreux comptes valides (root, admin, administrator, webadmin, ...). C'est une faille de sécurité importante car elle permet à l'attaquant d'avoir une liste d'identifiants à utiliser pour une attaque de phishing ou de brute force.

Il est nécessaire de configurer hMailServer pour désactiver la réponse aux requêtes VRFY EXPN. De plus, le serveur SMTP devrait bénéficier d'une authentification avant de divulguer n'importe quel informations concernant de potentiels boîte mail.

Pour finir la première phase de l'attaquant externe nous avons tester les vulnérabilités sur le port 80 avec deux outils : Nikto et Dirb. Le port 80 étant ouvert, nikto permet de scanner les erreurs de configuration et les failles connues du serveur web, puis ensuite dirb permet de découvrir de potentiel dossiers ou fichiers cachés par force brute de répertoires.

```
(kali@kali)-[~]
$ nikto -h http://203.0.113.1
- Nikto v2.5.0

+ Target IP:      203.0.113.1
+ Target Hostname: 203.0.113.1
+ Target Port:    80
+ Start Time:     2026-03-06 13:48:41 (GMT1)

+ Server: Apache/2.4.66 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 299e, size: 64c56ca36d43b, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS .
+ 8102 requests: 0 error(s) and 4 item(s) reported on remote host
+ End Time:      2026-03-06 13:51:24 (GMT1) (163 seconds)

+ 1 host(s) tested

*****
Portions of the server's headers (Apache/2.4.66) are not in
the Nikto 2.5.0 database or are newer than the known string. Would you like
to submit this information (*no server specific data*) to CIRT.net
for a Nikto update (or you may email to sullo@cirt.net) (y/n)? n
```

Figure 6 test de nikto sur le port 80 de 203.0.113.1

Le scan de nikto nous renvoie l'absence d'en-têtes de sécurité HTTP, comme X-Frame-Options. L'absence de cet en-têtes rend le site vulnérable aux attaques de type clickjacking.

Ensuite dirb, à permit d'identifier les répertoires cachés.

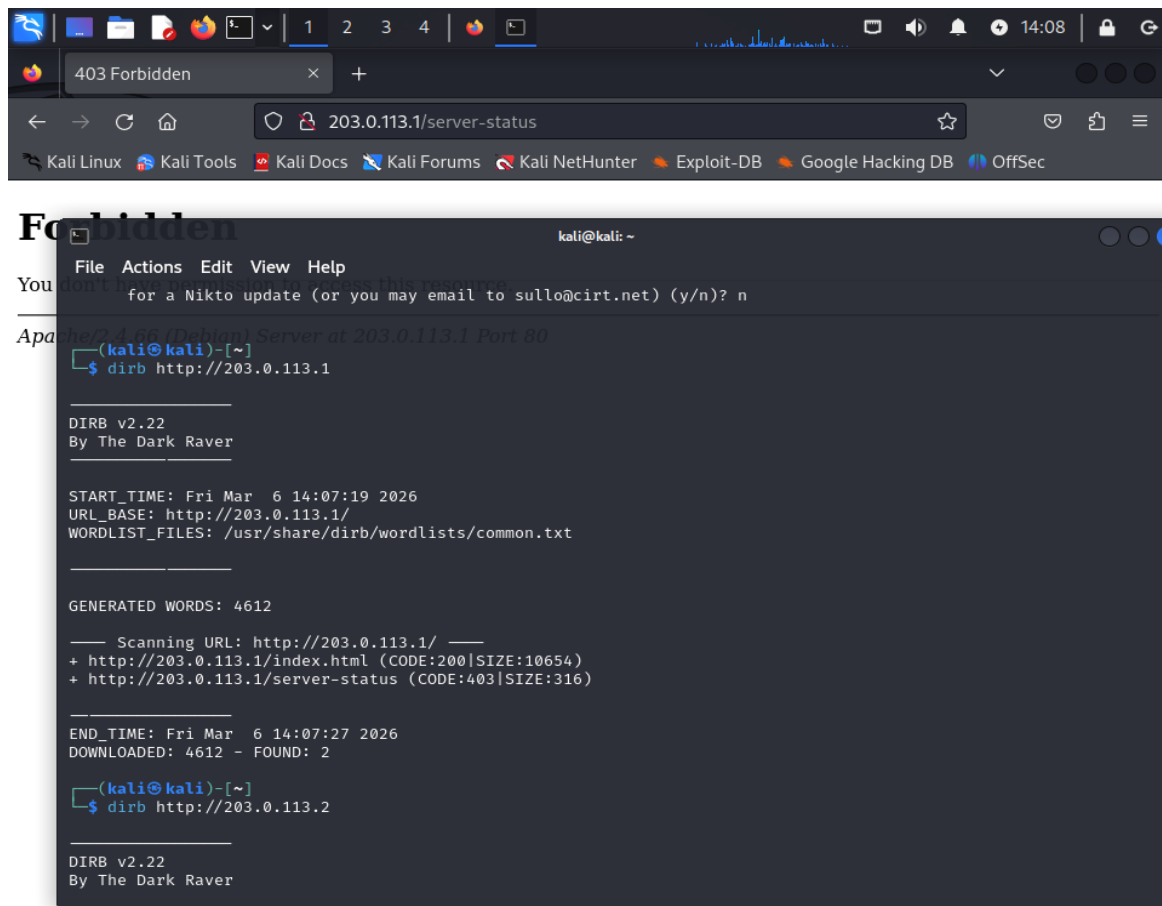


Figure 7 dirb sur 203.0.113.1

Dirb à trouver l'existence d'un répertoires /server-status. Bien qu'il ne soit pas accessibles (code 403 forbidden) ce qui indique qu'il y a quand même une restriction d'accès, le répertoires est détectable.

Pour les correctifs, concernant les en-têtes sur le serveur Apache il suffit de les activer puis d'ajouter des directives de sécurités dans le fichier de configuration (apache2.conf). Pour le répertoires /server-status, il faut désactiver le module mod-status s'il n'est pas utilisé pour de la supervision, cela permet de limiter le risque.

4.3 Phase attaquant interne

Lors de cette deuxième phase nous étions connecter au VLAN DATA et nous devons trouver le maximum de failles dans le réseaux 192.168.20.0/24. Nous avons débuter notre exploration du réseau interne par l'outil netdiscover. Netdiscover permet de repérer chaque hôte en effectuant un balayage ARP. De plus l'outil ip route permet de confirmer que nous somme bien dans le sous-réseau public de l'entreprise.

L'outil netdiscover nous as permis d'identifier plusieurs adresses IP ainsi que les adresses MAC et les constructeurs associés (pour la plupart Cisco). Cela nous permet d'avoir une liste d'équipements à cibler. De plus, netdiscover nous as permis d'identifier deux adresses IP de deux PC : 192.168.20.78 et 192.168.20.105. Nous en avons déduit que 203.0.113.1 était le routeur et que donc 203.0.113.11 était le switch du sous-réseau.

Concernant les correctifs, le protocole ARP est obligatoire sur un réseau local pour la communication donc il ne s'agit pas d'une faille direct. Cependant, on peut limiter la visibilité des interfaces importantes ou de désactiver le proxy ARP sur les interfaces des routeurs.

Pour finir nous avons essayé de casser le mot de passe de connexion SSH sur les interfaces 203.0.113.1 et .2 du routeur grâce à hydra et le dictionnaire rockyou.txt.

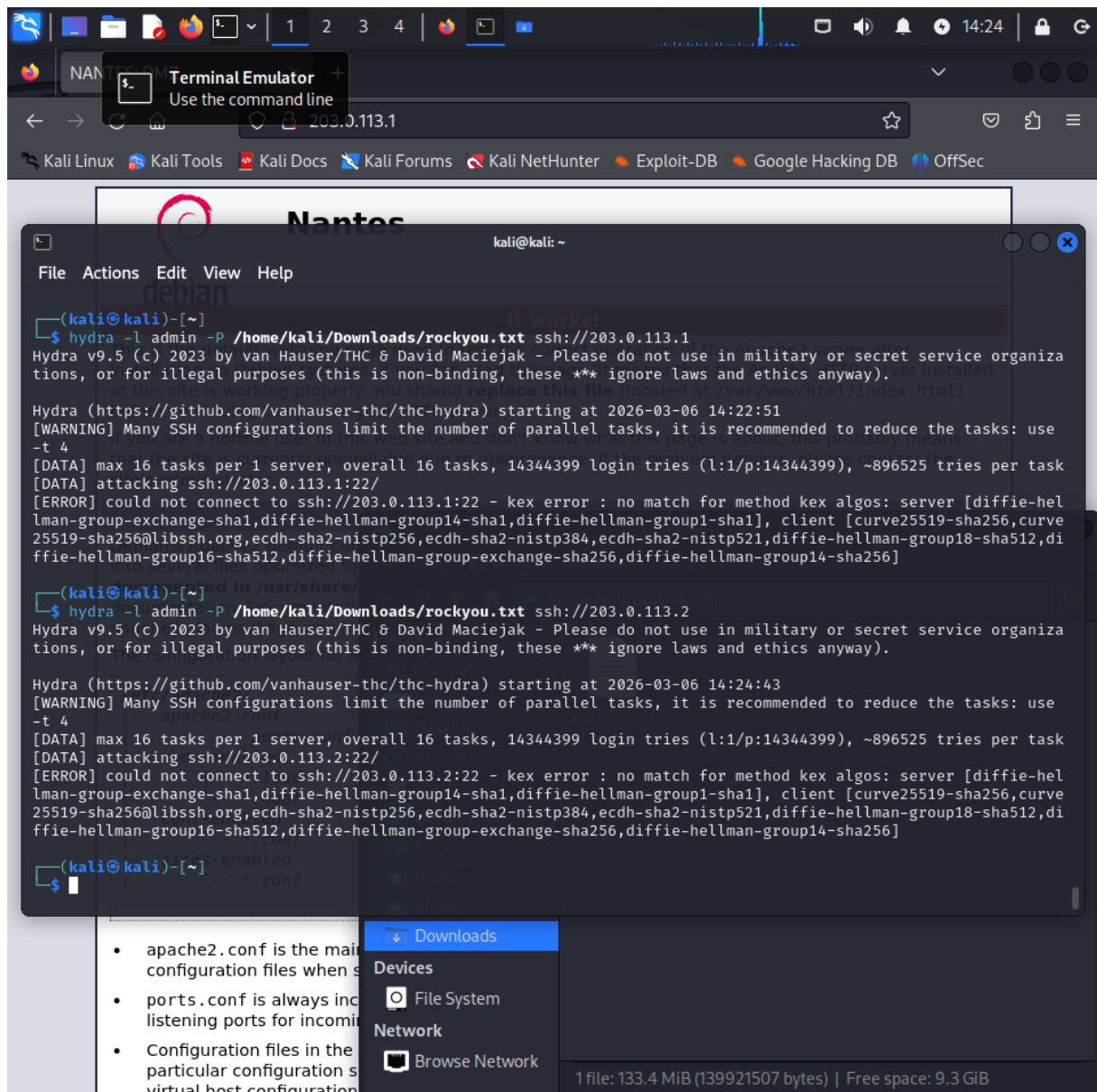


Figure 8 brute force du SSH avec hydra sur 203.0.113.1 et .2

L'attaque n'a pas pu fonctionner comme prévu en raison d'une erreur de cryptographie. Le routeur cisco utilisé un algorithme d'échange de clés obsolètes et faible (diffie-hellman-group1-sha1). Les clients SSH plus récents comme sur kali linux refusaient de communiquer avec cet algorithme trop daté. Malgré l'échec de l'attaque, l'obsolescent de l'algorithme d'échange de clés est une vulnérabilité au niveau de la cryptographie. L'utilisation de clé diffie-hellman de 1024 bits rend l'infrastructure vulnérable. Un attaquant disposant de serveurs assez puissant pourrait calculer, intercepter le trafic et déchiffrer la session SSH.

Afin de renforcer la connection SSH, il faut forcer l'utilisation de la version 2 de SSH et mettre à jour la configuration des routeurs. Ensuite, il faut

généraliser une nouvelles paires de clés RSA afin de sécuriser avec des algorithmes de chiffrements plus robustes les connexions SSH. Ainsi un attaquant ne pourra plus déchiffrer la session SSH car il faudrait un temps exponentiel.

5 Rôle dans l'équipe

Concernant la répartition des travaux réalisés lors de la mise en place de l'entreprise, Martin s'est occupé de la mise en place des équipements réseaux et Raphaël de la mise en place de la DMZ et de ses services.

Durant les trois premières heures, Martin a débuté par la configuration du routeur du site principal, du LAN et du site secondaire ainsi que les switchs de la DMZ, du LAN, et du site secondaire. Pendant ce temps, Raphaël a mis en place les trois serveurs DNS (racine, privé et public) ainsi que les différents services de la DMZ (web public, DNS public) et de l'intranet (Web privé, DNS privé). Ensuite pendant les 3h restantes, les deux nous avons réalisés la connexion du VPN IPsec entre le routeur du site principal et le routeur du site secondaire. Martin a continué sur la mise en place de SSH ainsi que de NAT et PAT sur l'ensemble des routeurs et Raphaël a fini les services de la DMZ avec la mise en place du serveur mail fonctionnant entre les deux pc clients communiquant via le VPN IPsec. A la fin des 6h de TP l'ensemble des services fonctionnait dans l'entreprise, le VPN IPsec fonctionnait et chaque ordinateur avait accès à internet. Le lendemain lors des 3h dédiées à la sécurité, Raphaël et Martin ont respectivement sécurisé le serveur web privé et public en implémentant de l'HTTPS, Martin a continué sur la mise en place d'ACL restreignant l'accès à l'intranet qu'aux PC situés dans le LAN. Raphaël a tenté de mettre en place du mail sécurisé qui n'a finalement pas fonctionné et a donc décidé de sécuriser l'ensemble des switchs en y intégrant de la protection face aux attaques de types MAC Spoofing, saturation d'adresses MAC, saut de VLAN et usurpation de spanning-tree sur chaque interface inutilisées pour réduire les possibilités d'attaques.

Lors de la phase d'attaque, Martin et Raphaël ont tous les deux participé aux 2 phases d'attaques. Lors de la première phase, Martin a utilisé nmap, hydra et smtp-enum-users, nikto tandis que Raphaël a utilisé netdiscover, dirb et nmap. Les mêmes outils ont été utilisés pour la deuxième phase réparties de la même manière.

6 Conclusion

En conclusion, la réalisation de cette infrastructure a permis de valider la convergence entre l'administration système et la sécurité offensive. L'interconnexion fonctionnelle des deux sites via le VPN IPsec démontre une maîtrise des protocoles de routage et de chiffrement (AES-256). L'implémentation des services en DMZ, couplée à une stratégie de NAT/PAT granulaire sur le routeur R-Principal, assure une exposition minimale des serveurs tout en maintenant leur accessibilité externe.

La phase de pentesting a été particulièrement instructive : elle a révélé que même une configuration fonctionnelle peut présenter des faiblesses critiques, comme l'usage de protocoles obsolètes ou des défauts de filtrage sur le plan de contrôle. L'audit nous a permis de réagir en renforçant les ACL d'administration (ACL-ADMIN-ONLY) et en sécurisant les accès SSH. Les protections de couche 2 appliquées sur les commutateurs (notamment le Port-Security et le filtrage des ports inutilisés) complètent cette approche de défense en profondeur.

Ce projet confirme l'importance d'une veille constante sur les vulnérabilités et de l'application rigoureuse des bonnes pratiques de l'ANSSI. Nous avons réussi à transformer un réseau initialement vulnérable en une infrastructure résiliente, capable de résister à des tentatives d'intrusion tant internes qu'externes, tout en assurant une continuité de service optimale pour les utilisateurs de l'entreprise.